INSTITUT PUIG CASTELLAR

A4.1. Exercicis: Enginyeria social i phishing

0226. Seguretat informàtica	GRUP: SMX2_
RA4. Assegura la privadesa de la informació transmesa en xarxes informàtiques descrivint vulnerabilitats i instal·lant programari específic.	
NOM I COGNOMS: Posa el teu nom i cognoms.	**DATA:** Escriu la data.

Enunciat de l'activitat:

Aquesta activitat es cenyeix a l'apartat NF5-AA1 (Enginyeria social, fraus i robatori d'informació) del RA4: tècniques d'enginyeria social, spam, protocols d'autenticació de correu i estratègies de prevenció.

Enunciat exercici 1

Completa una taula amb 6 tècniques d'enginyeria social (phishing, spear phishing, whaling, smishing, vishing, pretexting) indicant per a cadascuna:

a) el canal utilitzat (correu, SMS, telèfon...);

b) si va dirigida a una persona concreta o de manera massiva;

c) un exemple inventat i realista.

Enunciat exercici 2

Revisa la teva pròpia carpeta de correu brossa (spam) o demana a algú del teu entorn que te'n mostri exemples. Selecciona'n un i, sense fer clic a cap enllaç, analitza'l:

a) Quina adreça de remitent mostra, i sembla legítima?

b) Quin to fa servir (urgència, por, oportunitat)?

c) Quins 3 indicadors de sospita hi detectes (faltes d'ortografia, dominis estranys, peticions inusuals...)? [CAPTURA de l'assumpte i el remitent, sense fer clic a res]

Enunciat exercici 3

Explica què és un atac homogràfic (dominis amb caràcters visualment similars) i posa 3 exemples inventats de dominis falsos que podrien fer-se passar per "bancsabadell.com", "correos.es" i "amazon.es" respectivament.

Enunciat exercici 4

Explica la funció dels tres protocols SPF, DKIM i DMARC amb les teves paraules. Si una empresa NO configura correctament aquests protocols pel seu domini, quines dues conseqüències pràctiques pot tenir (tant per a qui envia com per a qui rep correus del seu domini)?

Enunciat exercici 5

Diferencia els tres tipus de filtres de correu brossa (llistes, heurístics, bayesians) explicant com funciona cadascun. Per què un filtre bayesià "aprèn" amb el temps, mentre que un filtre de llistes no?

Enunciat exercici 6

Una empresa (35 treballadors) pateix un intent de "frau del CEO": un empleat de comptabilitat rep un correu, aparentment del director general (però des d'un domini lleugerament diferent), demanant una transferència urgent i confidencial de 18.000€ a un compte nou. Elabora un informe que reculli:

1) quina tècnica d'enginyeria social identifiques i per quins indicis;

2) un protocol intern de verificació (per exemple, doble confirmació telefònica) que hauria evitat l'incident;

3) tres mesures de prevenció general (formació, MFA, filtres...) que recomanaries implantar a l'empresa;

4) si l'empleat NO hagués fet la transferència però hagués contestat el correu confirmant dades bancàries reals de l'empresa, quin risc legal (relacionat amb el RGPD, vist al RA5) podria derivar-se'n.

Fonts: Repositori "Materials" (GitHub, SMX-0226SI), NF5/AA1-EnginyeriaSocialPhising.md (CC-BY-SA-4.0); INCIBE, "Fraude del CEO"; ESET, "Phishing"; PowerDMARC, "All About SPF, DKIM, and DMARC".